SEDE CENTRAL: HOUSTON, TEXAS (EE. UU.)

ESTÁNDAR ISO/IEC 27001:2022

TDPSA & CÓDIGO 521

OrderSync Enterprise

Manual Integral de Calidad, Arquitectura Criptográfica y Operación de los 11 Módulos

Guía completa que documenta las regulaciones de calidad y privacidad del Estado de Texas, la justificación jurídica y técnica de la norma ISO 27001, y el funcionamiento exhaustivo de cada módulo del sistema en entornos de alta demanda.

JURISDICCIÓN Y SEDE

Houston, Texas, EE. UU. (Hub Central)

LEYES DE TEXAS IMPLEMENTADAS

TDPSA (Cap. 541) & Código 521 (Sec. 521.052/053)

SEGURIDAD DE LA INFORMACIÓN

ISO/IEC 27001:2022 / AES-256-CBC / KMS / TOTP

INFRAESTRUCTURA Y NUBE

PostgreSQL Neon Serverless (SSL) + Socket.io

ÍNDICE GENERAL

Estructura del Manual

SECCIÓN	TEMA PRINCIPAL	OBJETIVOS Y NORMATIVAS
Capítulo 1	Visión General de OrderSync y Arquitectura	Problemática del eCommerce multicanal y sincronización en tiempo real.
Capítulo 2	Estándares de Calidad y Leyes del Estado de Texas	TDPSA (Cap. 541), Texas Code Cap. 521, DSR, anonimización y notificación OAG.
Capítulo 3	¿Por qué Texas Exige la Norma ISO 27001?	Fundamento jurídico: Medidas razonables, Cláusula Safe Harbor y TCSAC.
Capítulo 4	Desglose Exhaustivo de los 11 Módulos	Funcionalidades, botones, pantallas y aportes de calidad de cada módulo.
Capítulo 5	Ciclo de Vida E2E: De la Venta al Restock	Flujo paso a paso con trazabilidad criptográfica y auditoría forense.
Capítulo 6	Credenciales, Roles y Puertos de Operación	Acceso seguro, matriz de permisos RBAC y directivas de producción.

Enfoque Territorial de Calidad: OrderSync fue diseñado bajo los requerimientos comerciales y regulatorios de **Texas**, estado que concentra el 44% de las operaciones logísticas del sistema (Hub Houston-Austin-Dallas). Toda la plataforma está alineada con el estándar de ciberseguridad más exigente de los Estados Unidos.

CAPÍTULO 1

Visión General de OrderSync y Arquitectura

¿Qué es OrderSync?

OrderSync es un Sistema de Gestión de Pedidos e Inventario Omnicanal (OMS) diseñado para unificar en tiempo real las operaciones comerciales de empresas de comercio electrónico que venden simultáneamente en **Shopify**, **Amazon Seller Central**, **Mercado Libre** y **WooCommerce**.

⚡ Sincronización en < 150ms

Evita la sobreventa deduciendo el stock inmediatamente en todos los canales conectados al ocurrir una compra.

🛡️ Cifrado de Grado Bancario

Los datos sensibles de los clientes (PII) viajan y se guardan cifrados con AES-256-CBC en Neon PostgreSQL.

🔄 Gestión de Retornos (RMA)

Ciclo de vida completo de devoluciones con restock físico automático y sincronización de órdenes a estado 'refunded'.

📊 Observabilidad DevOps

Telemetría de CPU, RAM, contenedores Docker y streaming de logs por WebSockets para soporte de misión crítica.

Diagrama de Flujo de Datos y Eventos



CAPÍTULO 2

Estándares de Calidad y Leyes del Estado de Texas

La sede operativa de OrderSync está situada en **Houston, Texas**. Por ello, la arquitectura del software no utiliza patrones genéricos de desarrollo, sino que implementa rigurosamente el marco regulatorio del Estado de Texas:

1. Texas Data Privacy and Security Act (TDPSA - Tex. Bus. & Com. Code § 541)

Entrada en vigor el **1 de julio de 2024**, la ley TDPSA es una de las legislaciones de privacidad más avanzadas de los Estados Unidos. Establece que los consumidores tienen derechos explícitos sobre el tratamiento de su información personal.

- **Derecho al Olvido y Supresión (Sec. 541.051):** OrderSync incluye el endpoint nativo `POST /api/security/dsr/erasure/:customerId`. Al recibir una solicitud, el sistema reemplaza inmediatamente el nombre y teléfono del cliente por `ANONYMIZED_TDPSA_CONSUMER` y la dirección por `REDACTED_PER_TEXAS_DATA_PRIVACY_ACT`.
- **Preservación Tributaria Legal (Sec. 541.055):** Conforme a la legislación fiscal de Texas, el sistema disocia la identidad del comprador pero **conserva intactos los montos numéricos, impuestos y registros contables** durante 7 años para auditorías del *Texas Comptroller of Public Accounts* (Contralor de Cuentas Públicas de Texas).
- **Aviso de Privacidad Obligatorio:** La aplicación publica de forma programática el endpoint `GET /api/security/texas-privacy-notice` con el desglose exigido de categorías de datos recolectados y su finalidad operativa.

2. Texas Identity Theft Enforcement and Protection Act (Capítulo 521)

- **Deber de Salvaguardar la Información (Sec. 521.052):** Exige a cualquier empresa en Texas implementar medidas de seguridad estrictas para proteger información confidencial. OrderSync cumple este mandato cifrando en reposo toda PII con **AES-256-CBC** y vectores de inicialización (IV) aleatorios por fila.
- **Protocolo de Notificación de Brechas (Sec. 521.053):** Obliga a notificar cualquier incidente de seguridad de datos en menos de 60 días a los consumidores afectados, y de forma mandatoria al **Fiscal General de Texas (Office of the Attorney General - OAG)** si la brecha involucra a 500 o más residentes de Texas. OrderSync cuenta con una bitácora inmutable de auditoría forense para sustentar investigaciones oficiales.

3. Protección de Infraestructura (Texas DIR / Cybersecurity Framework)

El Departamento de Recursos de Información de Texas (Texas DIR) dicta las normas para evitar colapsos en sistemas digitales. OrderSync incorpora limitadores de tasa (Rate Limiting) en Express para neutralizar ataques de denegación de servicio (DDoS) y fuerza bruta en los endpoints de autenticación.

CAPÍTULO 3

¿Por qué Texas Exige la Norma ISO/IEC 27001:2022?

Una pregunta habitual de directores de tecnología y auditores es: "*Si Texas ya tiene sus propias leyes estatales (TDPSA y Cap. 521), ¿por qué también exige o recomienda formalmente la certificación ISO 27001?*". La respuesta radica en la estructura jurídica y operativa del estado:

> **El Principio Jurídico de "Medidas Razonables de Seguridad":** El *Texas Business and Commerce Code § 521.052* exige a las organizaciones implementar "*reasonable security procedures and practices*". Sin embargo, la ley estatal no define los miles de controles técnicos detallados. Por jurisprudencia de los tribunales de Texas y las directrices del Procurador General (OAG), la norma internacional **ISO/IEC 27001:2022** es el estándar de oro reconocido para demostrar que una empresa cumplió con esa debida diligencia.

Las 4 Razones Fundamentales por las que Texas Pide ISO 27001

1. Protección Legal "Safe Harbor"

Ante una investigación de la Fiscalía General de Texas por un ciberataque, contar con un Sistema de Gestión de Seguridad de la Información (SGSI) basado en ISO 27001 exime o mitiga drásticamente las sanciones económicas multimillonarias al demostrar que no hubo negligencia empresarial.

2. Alineación con Texas Cybersecurity Framework

El estándar oficial del Estado (TCSAC) emitido por el Texas DIR está mapeado directamente con el Anexo A de ISO 27001. Cumplir ISO 27001 garantiza automáticamente la homologación con los requerimientos de ciberseguridad del gobierno texano.

3. Exigencia en Contratos B2B en Texas

Los gigantes logísticos y de retail con base en Houston, Dallas y Austin (Dell, Sysco, H-E-B, etc.) exigen contractualmente a sus socios tecnológicos e integradores de software estar certificados en ISO 27001 para permitirles conectarse a sus cadenas de suministro.

4. Trazabilidad Forense Inmutable

El control ISO 27001 A.8.15 (Logging) exige el registro inalterable de accesos. Si un operador consulta la dirección de un cliente, queda un rastro auditable que satisface los requerimientos forenses de los juzgados del Estado de Texas.

Matriz de Correspondencia: Ley de Texas vs. Controles ISO 27001 en OrderSync

EXIGENCIA LEGAL DE TEXAS	CONTROL ISO/IEC 27001:2022	IMPLEMENTACIÓN CONCRETA EN ORDERSYNC
Tex. Bus. & Com. Code § 521.052 (Salvaguarda de PII)	**A.8.24: Uso de Criptografía**	Cifrado AES-256-CBC de extremo a extremo en la base de datos Neon con rotación de claves KMS.
Tex. Bus. & Com. Code § 521.053 (Notificación e Investigación)	**A.8.15: Registro de Eventos (Logs)**	Tabla inmutable `audit_logs` que registra usuario, IP, módulo y acción en cada visualización de datos.
Texas DIR Guideline (Autenticación de Acceso)	**A.5.17: Información de Autenticación**	Doble Factor de Autenticación (MFA/TOTP) obligatorio y hashing seguro de contraseñas con salt.
TDPSA § 541.051 (Control de Datos Personales)	**A.8.11: Enmascaramiento de Datos**	Data Masking en la interfaz gráfica (solo los roles autorizados pueden presionar "Revelar PII").
Texas Business & Commerce § 541.101 (Evaluaciones de Impacto)	**A.5.8: Seguridad de la Información en Proyectos**	Arquitectura *Security-by-Design* que valida firmas criptográficas HMAC en cada webhook entrante.

CAPÍTULO 4

Desglose Exhaustivo de los 11 Módulos del Sistema

1. Dashboard Principal (Resumen Operativo & Órdenes)

El corazón visual del sistema. Consolida en una sola pantalla los eventos multicanal con latencia inferior a 150 ms gracias a WebSockets.

- **Tarjetas KPI en Vivo:** Facturación del día en USD, total de pedidos recibidos, latencia de sincronización en milisegundos y contador de productos en nivel crítico de inventario.
- **Monitor de Pedidos Multicanal:** Tabla unificada con filtros dinámicos por canal (Shopify, Amazon, Mercado Libre) y estados de pago.
- **Botón 'Devolución / RMA':** Permite registrar un reclamo de cliente directamente desde la orden, precargando el ID del pedido, el SKU, el cliente y el importe exacto.
- **Inspección de PII con Auditoría:** Permite visualizar los ítems del pedido; el nombre y dirección del cliente se muestran enmascarados hasta que un usuario autorizado solicita su revelación.
- **Aporte a la Calidad de Texas:** Centraliza la visibilidad de los pedidos del Hub de Texas, asegurando cumplimiento de SLA de despacho en menos de 24 horas.

2. Métricas y Analítica Avanzada (Metrics)

Panel de inteligencia de negocios para directores de operaciones y analistas financieros.

- **Distribución de Ventas por Canal:** Gráficos que comparan el volumen y rentabilidad neta generada por cada marketplace.
- **Curvas de Latencia Percentil (P95 y P99):** Monitorea los tiempos de respuesta de las APIs de comercio para identificar cuellos de botella antes de que afecten al cliente.
- **AOV (Average Order Value) y Tasa de Cumplimiento:** Métricas de ticket promedio y porcentaje de pedidos despachados dentro de la ventana de compromiso.
- **Aporte a la Calidad de Texas:** Reporta la concentración de pedidos en el Hub de Texas (44%) para optimizar la asignación de inventario regional.

3. Canales Omnicanal e Integraciones (Channels)

Consola de gobernanza técnica para la vinculación con plataformas externas de venta.

- **Conector Oficial de Shopify:** Soporta REST Admin API y GraphQL para consultas masivas de catálogo y suscripción a Webhooks.
- **Conectores Amazon SP-API y Mercado Libre:** Gestión de credenciales OAuth 2.0 y sincronización periódica de listados.
- **Verificación HMAC-SHA256:** Cada webhook recibido es verificado matemáticamente contra el secreto del canal antes de aceptar la orden.
- **Aporte a la Calidad de Texas:** Cumple con el estándar de integridad de datos del Texas DIR, impidiendo que peticiones falsas o maliciosas inyecten órdenes no autorizadas.

4. Control de Inventario Centralizado (Inventory)

Catálogo unificado maestro que garantiza la paridad absoluta de stock en todas las tiendas.

- **Catálogo Maestro por SKU:** Ficha técnica con SKU universal, código de barras, nombre, costo de compra, precio de venta e imagen.
- **Gestión de Stock Tripartito:** Stock físico en almacén, stock comprometido en pedidos en tránsito y stock neto disponible para venta.
- **Alertas de Reorden Inteligentes:** Notificaciones visuales de color ámbar y rojo cuando las unidades caen por debajo del umbral mínimo de seguridad.
- **Botón de Sincronización Forzada:** Actualiza al instante el inventario de un producto en Shopify y Amazon con un solo clic.
- **Aporte a la Calidad de Texas:** Previene la infracción comercial por falsa publicidad o venta de artículos agotados, protegida por el Código de Comercio de Texas.

5. Gestión de Proveedores y Compras (Suppliers)

Administración de la cadena de suministro inicial y el reabastecimiento de bodegas.

- **Directorio Maestro de Proveedores:** Registro de fabricantes (ej. Apex Global Electronics en Texas) con plazos de entrega (lead times) y términos de crédito.
- **Generación de Órdenes de Compra (PO):** Creación de pedidos formales a proveedores con costos unitarios pactados.
- **Recepción con Ingreso Automático a Stock:** Al confirmar la llegada del embarque al almacén, el sistema incrementa automáticamente las existencias del catálogo.
- **Aporte a la Calidad de Texas:** Documenta la procedencia de la mercancía y preserva la cadena de custodia exigida por las aduanas y reguladores comerciales.

6. Directorio CRM y Clientes (Customers)

Expediente centralizado de compradores con estrictas medidas de protección de datos personales.

- **Perfil Unificado Multicanal:** Vincula todas las transacciones de una misma persona aunque compre por distintos canales.
- **Cálculo de LTV (Lifetime Value):** Muestra el valor acumulado del cliente y su lealtad comercial.
- **Botón de Ejercicio de Derechos TDPSA:** Permite tramitar solicitudes de borrado o acceso de datos personales en un solo paso.
- **Aporte a la Calidad de Texas:** Centro neurálgico del cumplimiento del Capítulo 541 del Código de Texas (TDPSA) y de la confidencialidad de la información.

7. Usuarios, Roles y Permisos RBAC (Users)

Control de acceso basado en roles con separación estricta de funciones operativas y de seguridad.

- **Roles Preconfigurados:**
  - `SuperAdmin`: Acceso total e ilimitado a los 11 módulos, auditoría, llaves criptográficas y devops.
  - `Admin`: Gestión operativa completa de pedidos, inventario y logística sin acceso a infraestructura.
  - `Operator`: Acceso enfocado a despacho de órdenes, inventario y procesamiento de devoluciones.
  - `Auditor`: Permiso exclusivo de solo lectura para reportes financieros, métricas y bitácoras de seguridad.

- **Matriz de Permisos Granular:** Permite habilitar o inhabilitar individualmente cualquiera de los 11 módulos para usuarios específicos.
- **Aporte a la Calidad de Texas:** Satisface el principio de mínimo privilegio exigido por la norma ISO 27001 (A.5.15) y las directrices de ciberseguridad del Estado de Texas.

8. Seguridad, Cumplimiento y Cifrado (Security)

Consola de supervisión de ciberseguridad, criptografía y gobernanza de la información.

- **Monitor de Cifrado AES-256:** Visualiza en tiempo real el estado de los datos en reposo y certifica que los registros estén protegidos con hashes y claves vigentes.
- **Rotación Dinámica de Llaves (KMS):** Permite recifrar la base de datos completa con una nueva clave maestra sin interrumpir las ventas en vivo.
- **Visor de Bitácora de Auditoría Forense:** Consulta inmutable de accesos con filtros por usuario, fecha, dirección IP y tipo de operación efectuada.
- **Aporte a la Calidad de Texas:** Es la evidencia documental directa para el cumplimiento del *Texas Code § 521.052* e inspecciones de la norma ISO/IEC 27001:2022.

9. Logística y Rastreo de Envíos (Logistics)

Control integral de la preparación de paquetes, despacho con mensajerías y entrega de última milla.

- **Integración con Couriers Oficiales:** Genera guías de envío compatibles con **DHL Express**, **FedEx**, **Estafeta** y **UPS**.
- **Timeline de Checkpoints Interactivo:** Visualiza las etapas del envío: *Orden Recibida* ➔ *En Preparación* ➔ *En Tránsito* ➔ *En Aduana* ➔ *En Reparto* ➔ *Entregado*.
- **Detección Temprana de Incidencias:** Alertas visuales sobre retrasos de transporte, direcciones incorrectas o intentos de entrega fallidos.
- **Aporte a la Calidad de Texas:** Optimiza las rutas hacia y desde el Hub Central de Texas, reduciendo costos de flete interestatal y tiempos de entrega.

10. Devoluciones y Reembolsos (Returns & Refunds / RMA)

Módulo integral para la gestión de retornos, satisfacción de garantía y reingreso a bodega.

- **Ciclo de Vida de 4 Fases:**
  1. `requested`: Devolución solicitada por el comprador o por el agente de soporte.
  2. `approved`: Caso analizado y aprobado; se emite la guía de retorno para el cliente.
  3. `received_restocked`: El paquete llega a almacén, pasa inspección física y **se reingresa el stock al inventario automáticamente**.
  4. `rejected`: Solicitud denegada por no cumplir las políticas de garantía o daños deliberados.
- **Actualización Automática de Órdenes:** Al procesar la devolución con restock, el pedido en el sistema cambia inmediatamente a estado `refunded` (reembolsado).
- **Integración con Webhooks de Reembolsos de Shopify:** Si se emite un reembolso en el panel de Shopify, el webhook `refunds/create` crea la devolución en OrderSync de forma transparente.
- **Aporte a la Calidad de Texas:** Protege el derecho del consumidor bajo las leyes de garantía comercial de Texas y evita discrepancias contables.

11. DevOps, Monitoreo y Salud del Sistema (DevOps)

Centro de supervisión de infraestructura y observabilidad de microservicios en producción.

- **Métricas de Hardware en Vivo:** Porcentaje de uso de CPU, consumo de memoria RAM, lectura/escritura de disco y uptime del servidor.

- **Salud de Contenedores Docker:** Estado operativo (*Healthy / Running*) de los servicios de Node.js, frontend Angular y PostgreSQL Neon.
- **Tuberías de CI/CD:** Estado de compilaciones, suites de pruebas automatizadas y versiones desplegadas.
- **Consola de Logs en Streaming:** Transmisión por WebSockets de los registros del servidor con filtrado por niveles (`INFO` , `WARN` , `ERROR` , `FATAL`).
- **Acciones de Resiliencia:** Botones seguros para purgar memoria caché y reiniciar microservicios en caso de contingencia técnica.
- **Aporte a la Calidad de Texas:** Asegura una disponibilidad 24/7/365 superior al 99.9% exigida en acuerdos de nivel de servicio (SLA) corporativos de Texas.

CAPÍTULO 5

Flujos Operativos Extremo a Extremo (E2E)

Flujo 1: Recepción de Pedido, Cifrado y Despacho

ETAPA	DISPARADOR / EVENTO	ACCIÓN INTERNA DE ORDERSYNC	GARANTÍA DE CALIDAD
1. Venta	Compra realizada en tienda Shopify o Amazon.	Shopify emite webhook `orders/create` con firma HMAC.	Validación de firma criptográfica en el middleware.
2. Cifrado	Ingreso de datos personales al backend.	Se aplica AES-256-CBC al nombre, teléfono y dirección del cliente.	Cumplimiento directo con Texas Code § 521.052.
3. Stock	Deducción automática de inventario.	Se descuenta `stock = stock - 1` en la base de datos Neon.	Prevención de sobreventa en los demás canales.
4. En Vivo	Emisión de eventos WebSocket.	El servidor emite `ORDER_CREATED` e `INVENTORY_UPDATED`.	Actualización en pantalla en menos de 150 milisegundos.
5. Envío	Operador asigna guía en Logística.	Se genera tracking DHL y se vincula al pedido.	Trazabilidad de entrega de última milla.

Flujo 2: Devolución, Restock en Bodega y Reembolso

ETAPA	DISPARADOR / EVENTO	ACCIÓN INTERNA DE ORDERSYNC	GARANTÍA DE CALIDAD
1. Solicitud	Cliente pide retorno de mercancía.	Clic en botón **Devolución / RMA** de la orden en el Dashboard.	Generación de número RMA oficial (ej. `RET-2026-4821`).
2. Aprobación	Supervisor valida el motivo.	Se presiona **Aprobar Devolución** (estado `approved`).	Emisión de guía de recolección al cliente.
3. Bodega	El paquete arriba al almacén.	El bodeguero presiona **Recibir e Ingresar a Stock**.	El inventario suma las unidades: `stock = stock + quantity`.
4. Reembolso	Acreditación del importe.	La orden cambia automáticamente a estado `refunded`.	Sincronización de libros contables y auditoría.

> **Trazabilidad Inmutable:** Todo el ciclo de vida queda registrado con fecha, hora, usuario e IP en la tabla de auditoría (ISO 27001 A.8.15), garantizando transparencia ante cualquier litigio comercial o auditoría fiscal en el Estado de Texas.

CAPÍTULO 6

Credenciales, Configuración y Accesos al Sistema

Servicios Activos y Puntos de Conexión

COMPONENTE	DIRECCIÓN / PUERTO	TECNOLOGÍA	FUNCIÓN EN EL ECOSISTEMA
Frontend Web	`http://localhost:4200`	Angular 17 Standalone	Interfaz de usuario, dashboard y control de los 11 módulos.
API Backend	`http://localhost:3000`	Node.js Express TypeScript	Lógica de negocio, cifrado AES-256 y API RESTful.
WebSockets	`ws://localhost:3000`	Socket.io Engine	Canal de eventos en vivo para órdenes, stock y logs.
Base de Datos	`ep-billowing-fire-a4rfxljl.us-east-1.aws.neon.tech`	PostgreSQL Neon Cloud	Almacenamiento relacional serverless con SSL forzado.

Cuentas de Acceso Preconfiguradas en el Entorno

USUARIO / CORREO	CONTRASEÑA	ROL ASIGNADO	MÓDULOS HABILITADOS
`admin@ordersync.io`	`AdminPass123!`	SuperAdmin	**Todos los 11 módulos** (Control total, seguridad, llaves y DevOps).
`operator@ordersync.io`	`Operator123!`	Operator	Dashboard, Inventario, Logística y Devoluciones.
`auditor@ordersync.io`	`Auditor123!`	Auditor	Métricas, Seguridad, Clientes y Bitácora de Auditoría.

Soporte Bilingüe Reactivo

La aplicación está internacionalizada en **Español** e **Inglés** mediante el servicio `TranslationService`. El idioma se conmuta instantáneamente desde la barra de navegación superior sin perder el estado de la sesión ni las vistas activas.

OrderSync Enterprise v2.4

Houston, Texas Headquarters — Hub Central de Operaciones Omnicanal.
Alineado con TDPSA, Texas Business & Commerce Code Cap. 521 y la norma ISO/IEC 27001:2022.
Documento confidencial para uso operativo y técnico exclusivo.